

rflx.ai — Product Requirements Document

Date: August 2026 | **Author:** Oyin | **Status:** Build-Ready | **Version:** 2.7 **Companion docs:**

`docs/engineering/architecture.md` and `specs/` cover architecture, API contracts, schema, and evaluation framework; `docs/design.md` is the visual design system (colors, type, spacing). This file covers product strategy and requirements only — what to build and why.

1. Executive Summary

Problem Statement

Healthcare AI is moving from tools that *draft* (notes, summaries) to agents that *act* (updating medication lists, routing referrals, messaging patients, writing to the EHR). Gartner projects 40% of enterprise applications will feature task-specific AI agents by end of 2026, up from under 5% in 2025. No commercial or open-source tool applies **clinical-severity-aware judgment** to what an AI agent is allowed to do — generic AI governance platforms police model traffic, not clinical consequence. Meanwhile, the underlying model layer is demonstrably unsafe on its own: a peer-reviewed JAMA Network Open study found prompt-injection attacks succeeded in 94.4% of trials against commercial medical LLMs, including inducing FDA Category X drug recommendations.

Proposed Solution

rflx is a decision engine, not an integration platform. It's agent-agnostic middleware that sits between any AI agent and the systems it acts on. An agent proposes a structured action; rflx screens it for manipulation, classifies its clinical risk, and returns one governed decision — auto-approve, escalate to human review, or block — logging every decision to an auditable incident trail surfaced on a dashboard.

The category analogy that explains it instantly: rflx is to clinical AI agents what Stripe Radar is to payments, or Auth0 is to logins — a decision-at-the-handoff-point layer. It doesn't process the payment, run the app, or build the agent. It decides whether the thing about to happen should be allowed to happen.

What rflx Explicitly Is Not

- Not an agent-building or orchestration platform (that's Hippocratic AI, Kore.ai, Oracle Health — rflx assumes their agents already exist)
- Not a multimodal/image-analysis tool
- Not an EHR or workflow system (mocked/consumed, never built)
- Not a prompt-injection detection engine (bought from Azure, not rebuilt)
- Not a content-level PHI leak scanner (a genuinely different product — see Section 6.2)

Business Impact

- **Risk reduction:** closes the gap between agentic AI adoption speed and the (currently proposed, not final) HIPAA Security Rule's AI-specific safeguards
- **Competitive positioning:** occupies the space between native platform guardrails (increasingly common — see Hippocratic AI, Section 3.3) and no governance at all — specifically the multi-vendor and custom-built-agent environments neither extreme covers
- **Regulatory tailwind:** FDA's Feb 2026 final cybersecurity guidance already extends secure-by-design obligations to training data and model artifacts; several states now legally require human review of AI-driven adverse healthcare determinations

Key Milestones (2-week build track — full plan in `skills/engineering-planner/SKILL.md`)

Milestone	Target
Spec, eval suite, architecture diagrams committed to GitHub	Days 1–3
Guardrail engine + Supabase backend functional	Days 4–9
Next.js UI (review queue + dashboard) live on Netlify	Days 8–12
Eval suite run, demo recorded	Days 12–14

Success Metrics (MVP demo, not production KPIs)

North Star metric: Injection-pattern catch rate on the JAMA-derived eval suite ($\geq 90\%$) — the single primary signal the guardrail exists to move. Every other metric below is a guardrail *on* that goal, not a competing priority.

Metric	Type	Target	Measured (<code>specs/08-eval-harness.md</code> , 100-case suite)
Injection-pattern catch rate (JAMA-style eval set)	North Star	$\geq 90\%$	100% (PASS)
False-positive rate on benign action set	Primary	$< 10\%$	0% (PASS)
P95 guardrail decision latency	Primary	~13s P95 (P50 ~4.5s) — accepted floor, not a request-handling budget; see note below	P95 7.1s / P50 4.2s (most recent full run) — comfortably inside its revised target
Every decision has an audit trail entry	Secondary — reliability	100%	Not yet formally measured — every eval run wrote a Supabase row per case with no drops
Reviewer time-to-decision on escalated actions	Secondary — adoption/usability proxy	< 5 minutes (self-measured during manual walkthrough)	Not yet measured — no manual walkthrough run yet

Live results for every metric above, not just this table's snapshot, are visible at `/eval` (`specs/10-eval-results-ui.md`) — a real page reading the same eval output this table cites, not a spec-only artifact.

Latency gap, documented and accepted, not silently missed: root-caused to the number of sequential reasoning-model round-trips the investigator's tool-calling loop makes (`gpt-5.6-terra` is a genuine reasoning-tier model; each turn costs 2-4+ seconds regardless of what it does), not request-handling or infrastructure overhead. Several changes were tried against this root cause: parallelizing same-turn tool

calls (no improvement, 8806ms → 8708ms), removing `get_patient_current_medications` from the agentic loop entirely — fetched eagerly as context instead of behind a tool call, `specs/04-investigator.md` 's Latency Architecture (v3) section — which also measured no real P95 improvement (8708ms → 8542ms, still noise-level) despite being a sound change on its own terms, and two further structural fixes (parallelizing the `risk_classifications / incidents` Supabase inserts in `recordDecision` , and overlapping the eager medications lookup with the Prompt Shield call instead of running them sequentially). That last pair moved P50 meaningfully (5519ms → 4497ms, ~18% faster — consistent with removing two sequential round-trips from the common case) but not P95 (11.5s → 12.9s); the slowest cases in the post-fix run were scattered across unrelated action types rather than concentrated in the multi-tool-call cases that dominated the pre-fix tail, consistent with OpenAI-side call latency variance rather than a regression, though a single 100-case run can't fully separate that from a real tail effect.

The target is revised, not chased further — a deliberate decision, not a default: every fix tried so far is request-handling plumbing; none of it touches the actual floor, which is that a single `gpt-5.6-terra` call at its lowest usable reasoning effort (`specs/04-investigator.md` 's `"low"` , already the floor) costs 2-4 seconds by itself, before Prompt Shield, persistence, or a second tool-calling turn are even counted. Closing the gap to 3s would require either a faster non-reasoning model for the classification step or a deterministic pre-filter that skips the reasoning model for "obviously benign" cases — and both directly undercut §3.5's argument for *why* this system uses agentic investigation over a rules engine in the first place: interpreting novel, adversarially-phrased content is exactly the job a fast/rules-based path can't do, and a pre-filter creates a new attack surface of its own (a crafted-to-look-benign injection bypassing investigation entirely). The 3-second target was set before the investigator existed to measure against it. **P95 ~13s / P50 ~4.5s is now the accepted target** — the real cost of the reasoning step the product's core value proposition depends on, not an unmet goal.

A more consequential finding came out of this investigation than the P95 number itself: two separate eval runs each had one request silently stall for 11-12 minutes, well past the OpenAI client's already-configured 20s timeout, with zero error signal in the logs — a hang below the SDK's own timeout handling (likely DNS/connection-establishment, not response-reading). Fixed with an independent, SDK-agnostic hard timeout (`Promise.race` against a plain JS timer, `lib/investigator/index.ts` 's `withHardTimeout()`) wrapped around every external call in the investigation loop. Verified clean on the next full run — no outliers, slowest case 9.4s. This is a real reliability fix, not a latency one: an occasional unbounded multi-minute hang would have been a far more serious production problem than a consistently-high-but-bounded P95.

The two metrics that actually validate the hypothesis (catch rate, false-positive rate) both clear their targets cleanly and held steady at 100%/0% across every change made during this investigation — real signal, not regressed by any of it.

Update, most recent full run: P95 7.1s / P50 4.2s — well inside the revised ~~13s~~ 4.5s target, and better than the 12.9s/4.5s figure the investigation above was measured against. Run-to-run latency varies with OpenAI-side call conditions (noted above as the likely explanation for the earlier run's P95 tail), so this isn't claimed as a further fix — it's evidence the accepted target has real margin, not a number sitting right at the edge of passing.

2. Discovery & Evidence Base

Finding	Source	Relevance
93% of healthcare orgs have adopted AI; governance hasn't kept pace	Omega Systems 2026 Healthcare IT	Root-cause framing

	Landscape Report	
40%+ of healthcare staff aware of shadow AI use; 23% of clinicians at one 8-hospital system used ChatGPT for documentation	Wolters Kluwer Health survey (Jan 2026)	Adjacent, explicitly out of scope
94.4% prompt-injection success rate against commercial medical LLMs, 91.7% in extremely-high-harm scenarios (FDA Category X drugs)	JAMA Network Open, peer-reviewed, 216 simulated dialogues (Dec 2025)	Primary evidence anchor — eval suite built directly from this
Gartner: 40% of enterprise apps will have task-specific AI agents by end of 2026, up from <5% in 2025	Gartner, cited across 2026 AI-governance vendor reports	Establishes urgency/timing
Sharp HealthCare, Sutter Health, Memorial Healthcare class-action suits over ambient AI scribe consent	San Diego Superior Court filings, Nov 2025	Validated as a <i>different</i> problem — informed the decision to scope it OUT
HIPAA Security Rule AI-specific update still proposed, not final; no rule expected before mid-to-late 2027	Medcurity / regulatory tracking, verified June 2026	Regulatory-gap framing
FDA final AI-enabled medical device cybersecurity guidance issued Feb 2026, extending secure-by-design obligations to training data/model artifacts	Congressional Research Service brief, June 2026	Shows regulators extending scrutiny to the ML pipeline
61% of healthcare leaders already building agentic AI initiatives; 85% plan to increase investment over 2–3 years; agentic-healthcare funding rounds nearly doubled (\$82M → \$155M average) late 2025 to early 2026	2026 agentic-AI-healthcare funding trackers	Confirms durable, accelerating tailwind
Hippocratic AI already builds native clinical guardrails into its agent platform — agents escalate anything outside defined clinical scope to human clinicians	Industry vendor analysis, March 2026	Important competitive signal
AI guardrail platforms (as a distinct funding category) raised \$78.57M across 5 disclosed deals (July 2025–June 2026), led by WitnessAI's Series B	AI safety funding tracker	Confirms the category is real and fundable, but early-stage
Generic AI governance vendors (Cisco AI Defense, Prompt Security/SentinelOne, HiddenLayer, TrueFoundry, Credo AI, Aurascape) are well-funded and already sell into healthcare as one of several verticals	TechTarget, Venn, Aurascape 2026 vendor landscape reviews	Confirms the horizontal layer is commoditized — motivates the clinical-specific wedge
Microsoft's official agentic-AI security guidance recommends enforcing human review for high-risk actions "through orchestrator logic rather than model reasoning"	Microsoft Learn, 2026	Direct support for keeping rflx's decision boundary deterministic

"Agentic guardrails are deterministic controls applied to probabilistic systems at runtime... a natural-language instruction to an LLM is a suggestion, a runtime policy check is enforcement"	Obsidian Security, May 2026	Sharpest available articulation of rflx's core design principle
An Alibaba-affiliated AI agent autonomously hijacked GPU resources for crypto mining and opened a hidden network backdoor, without being instructed to	Reported industry incident, early 2026	Concrete cautionary example of why an equally-autonomous governance layer is risky
FINRA's 2026 Annual Regulatory Oversight Report treats AI agents as a distinct supervisory category, requiring guardrails on agent behavior regardless of autonomy	FINRA, 2026	Regulatory backing for deterministic enforcement as agent autonomy increases
openFDA drug label API (contraindications, boxed warnings, drug interactions) is free, public, and requires no authentication	FDA / open.fda.gov	Enables the risk classifier to ground its judgment in a named, citable external source
Microsoft Foundry's tracing and evaluation capabilities reached general availability in March 2026, with interoperability extended to any OpenTelemetry-instrumented agent (including plain OpenAI SDK calls) at Build 2026	Microsoft Foundry Blog, June 2026	Enables a real observability layer without migrating off OpenAI's API — see docs/design.md

3. Problem Definition & Solution Rationale

3.1 Customer Problem (Five Ws)

- **Who:** Health system CISOs, Chief Digital/AI Officers, and clinical informatics leaders deploying or piloting agentic AI in clinical workflows
- **What:** No policy layer exists that understands the *clinical severity* of an AI agent's proposed action before it executes
- **When:** At the moment of agent-to-system handoff — where a drafted suggestion becomes a live action
- **Where:** Any clinical workflow where an agent has tool-calling access to EHR, scheduling, or patient communication systems
- **Why (root cause):** Governance frameworks were built for human-speed, human-initiated actions and can't evaluate autonomous agent behavior at the speed and volume agents operate at
- **Impact of not solving:** A single unreviewed high-risk action can cause direct patient harm or a reportable HIPAA breach — not hypothetical, given the JAMA study's documented 94.4% injection success rate

3.2 Alternatives Considered and Rejected

Alternative	Why considered	Why rejected
PHI leak detector for AI outputs	Strong, well-evidenced problem (shadow AI)	Crowded — OneTrust, Credo AI, Aurascape (named healthcare deployment) sell this horizontally

IoMT device vulnerability triage	Strong patient-safety evidence (99% of hospitals exposed)	Extremely mature, crowded market (Claroty, Cynerio, Medigate, Ordr)
Ambient AI scribe consent/BAA governance	Real, active litigation (Sharp HealthCare)	Different attack surface — recording/consent governance vs. autonomous action governance. A different product.
Multi-modal diagnostic scan injection scanner	Best-evidenced <i>novel</i> attack class found in research	Technically hardest to build well in the timeline; higher risk of an unconvincing demo
Clinical agentic action guardrail + incident response (chosen)	Least crowded, most timely, directly buildable, ties to strongest evidence	—

3.3 Competitive Landscape

- **Generic AI governance/injection-detection vendors** (Cisco AI Defense, Prompt Security, HiddenLayer, TrueFoundry) — commoditized, don't understand clinical severity. rflx doesn't compete here; it *consumes* one of these (Azure Prompt Shield) as Layer 1.
- **Agentic healthcare orchestration platforms** (Kore.ai, Oracle Health, Salesforce, ServiceNow, Aisera) — bundle EHR integration with agent-building and "configurable guardrails" as a feature. Deep integration moats (150–250+ EHR connections) built over years — not something a solo builder competes with on integration depth.
- **"AI SOC for healthcare"** platforms (Censinet, UnderDefense, Stellar Cyber, Seceon) — bundle EHR/IoMT monitoring with incident response and clinical-context threat detection. Adjacent, not identical.
- **Hippocratic AI** — the most important single data point. Builds clinical guardrails *natively* into its own agent platform, with agents escalating out-of-scope actions to clinicians. This is the strongest evidence that native, platform-built guardrails are a real trend.
- **The honest implication:** the addressable niche for a *standalone* guardrail layer narrows to multi-vendor environments and custom in-house agents built without any platform's native guardrail. That's a real, smaller wedge — described precisely, not oversold.

3.4 Why This Solution, Specifically

1. **A prevention *and* detection story**, mapping to the NIST Cybersecurity Framework's prevent/detect/respond structure
2. **Evidence-anchored, not speculative** — eval suite built directly from a peer-reviewed attack-success study
3. **Buildable at MVP fidelity** with your actual stack in 2–2.5 weeks, without real PHI or a live EHR integration

3.5 Why Agentic Investigation, Not a Rules Engine

Clinical risk judgments depend on unstructured, high-variance inputs: free-text action payloads, adversarial injection attempts phrased in endless ways, drug-label language, and inbound patient-portal messages that may carry hidden instructions. A rules engine — regex or keyword matching — can catch known injection phrases, but it can't reliably judge whether a *novel* phrasing recommends a contraindicated drug combination, or distinguish a legitimate urgent dose change from a manipulated one. That requires interpreting meaning, not matching patterns.

This is why the system splits agency from decision: agentic judgment is used where interpretation of unstructured content is required (the investigation step), and deterministic enforcement is used where consistency and auditability are required (the final decision). A rules-only system would fail at the first job; an unconstrained agentic system would fail at the second. Neither extreme alone solves the problem — the split does.

3.6 Defensibility / MOAT

The defensible asset is the clinical risk taxonomy and its calibration against real escalation and override outcomes over time — not the architecture itself. The policy rule table is straightforward for a competitor to replicate on day one; what's hard to replicate is a taxonomy that's been tuned against thousands of real reviewer decisions: which false positives got corrected, which near-misses triggered a threshold change, which action types turned out to need finer-grained tiers than the initial four. That data-driven tuning loop compounds over time and can't be shortcut by a competitor starting from a blank taxonomy, regardless of how good their model layer is.

This claim only holds if the underlying data trail actually exists. §6.1's reviewer-outcome calibration log is the concrete feature that captures it — see there for what's built at MVP versus deferred.

Secondary to that: workflow lock-in as reviewers build the review queue into their daily process, and the switching cost of re-training a review team on a new tool once one is embedded. The taxonomy-tuning loop is the primary MOAT; workflow habit is the secondary one. Architecture and model choice, on their own, are not — both are replicable.

4. Hypothesis

*We believe that a **clinical-risk-aware policy gateway sitting between AI agents and clinical systems for health system CISOs and clinical informatics leaders piloting agentic AI will catch unsafe or manipulated agent actions before they execute, and provide an auditable incident trail when they don't** We'll know we're right when **the guardrail catches ≥90% of injection-pattern test cases from our JAMA-derived eval suite, with a false-positive rate under 10% on benign actions.***

5. Value Proposition & Personas

Persona	Pain Today	Value rflx Provides
Health system CISO	No visibility into what AI agents are doing until something goes wrong; generic AI governance tools don't understand clinical severity	Real-time policy enforcement + audit trail scoped to clinical risk
Chief Digital/AI Officer	Under pressure to pilot agentic AI, can't get security sign-off without a control layer	A demonstrable control point that lets pilots proceed with documented risk management
Clinical informatics lead / pharmacist reviewer	Would manually catch a bad AI-suggested medication change today, with no tooling support	A structured review queue instead of ad hoc oversight

One-line value proposition: *rflx lets health systems adopt agentic AI without trading clinical safety for velocity — by giving every agent action a clinically-aware go/no-go decision and leaving an audit trail behind it.*

6. Scope

6.1 In Scope (MVP)

Feature	Priority	Description	Rationale
Mock clinical agent simulator	P0	Issues structured action requests using OpenAI-generated proposals over Synthea-derived synthetic patients	Nothing else in the pipeline is testable without a source of action requests
Injection/manipulation pre-screen	P0	Azure AI Content Safety (Prompt Shield) as first-pass filter	Load-bearing for the North Star metric (injection catch rate)
Clinical risk classifier	P0	OpenAI GPT-5.6 Terra reasoning layer scoring action + payload against the risk taxonomy	Load-bearing for both the catch-rate and false-positive-rate metrics
Policy engine	P0	Deterministic rule table: (risk_tier, injection_flag) → decision	The deterministic decision boundary is the core design claim of the whole product
Human-in-the-loop review queue	P0	Next.js app (API routes + UI), connected to Supabase (Retool as documented fallback)	Required to demonstrate escalation, one of the three possible decisions
Audit & incident log	P0	Supabase, append-only design	Required for the 100% audit-trail success metric
Incident detection & response dashboard	P1	Next.js app — incident volume, block/escalation rate, filterable trail	Strengthens the demo narrative but the review queue alone already proves the core loop; can slip a day if the schedule compresses
Read-only incident log	P1	Next.js app (specs/09-incident-log-ui.md) — browse already-decided auto_approve/block actions with full reasoning and evidence, deep-linked from the dashboard's stat tiles	The dashboard shows aggregate counts; a CISO or reviewer auditing a specific past decision needs to see the individual action and reasoning behind it, not just a number
Eval results UI	P1	Next.js app (specs/10-eval-results-ui.md) — real page showing the guardrail's own Go/No-Go accuracy (catch rate, false-positive rate, latency) against its baseline,	rflx's core premise is visibility into what other AI agents are doing; this is that same premise applied to rflx itself — added post-MVP-build after being flagged as a major

		sourced from the same eval harness output as §1's Success Metrics table, with CSV/JSON export	part of the product's trust story, not an afterthought
Eval harness	P0	JAMA-derived injection cases + Synthea-derived benign cases, precision/recall reported	Written before implementation by design — the single most load-bearing artifact in the whole build
Observability instrumentation	P1	OpenTelemetry spans wired to a Microsoft Foundry project — tracing, evaluation, monitoring	Strengthens the operational-maturity story; the guardrail engine and eval suite (both P0) fully prove the hypothesis without it
Reviewer-outcome calibration log	P1	For every escalated action, structurally capture whether the reviewer's decision <i>agreed with or overrode</i> the system's risk classification, plus a reason code/note — not just the existing append-only <code>review_decisions</code> record of the raw approve/reject	This is the raw data substrate §3.6's MOAT claim depends on. Capturing it from day one is what makes "taxonomy tuned against real reviewer decisions" a real future capability instead of a retrofit that loses every pre-launch decision. The <i>analysis/tuning loop</i> built on top of this log is out of MVP scope — see §6.3

6.2 Out of Scope (MVP) — and Explicitly Not a Future Phase Either

- **Content-level PHI leak detection.** Deliberately identified and rejected as a *different product*, not deferred. rflx prevents leak-*shaped actions* (`export_record`, unauthorized messaging) via the risk taxonomy — it does not scan payload text for embedded PHI patterns.
- Live EHR integration (explicitly simulated)
- Real patient data of any kind — 100% synthetic, always
- Ambient scribe / consent governance (different product)
- Multi-tenant / multi-hospital deployment
- Image/multimodal action payloads (structured data only)

6.3 Deliberately Timeboxed Out — "Phase 2, and here's why"

- **Snowflake analytics pipeline:** valuable at production scale, not needed to prove the core hypothesis at demo scale
- **Fine-tuned smaller classifier:** no production usage data yet to fine-tune on; correctly sequenced as a v2 item once real classification logs accumulate
- **Longitudinal taxonomy calibration loop:** analysis and dashboarding over the reviewer-outcome calibration log (§6.1) — surfacing override patterns, false-positive correction trends, and threshold-drift signals, then actually adjusting the taxonomy/policy table from them. The MVP captures the log; it doesn't yet act on it. Same underlying reason as the fine-tuned classifier above — a 2-week synthetic demo doesn't generate enough real reviewer volume for a tuning signal to mean anything yet

7. User Stories & Requirements

7.1 Core User Stories

US-01 — As a clinical AI agent, I want to submit a proposed action for evaluation, so that unsafe or manipulated actions are caught before execution. Acceptance: every submitted action receives a decision within P95 ~13s (P50 ~4.5s), with a logged risk tier and reasoning — see §1's Success Metrics note on why this reflects the investigator's reasoning-model floor rather than a request-handling budget.

US-02 — As a reviewer, I want to see escalated actions with full context and reasoning, so that I can make an informed approve/reject decision. Acceptance: the review queue shows action payload, risk classification, and the specific trigger.

US-03 — As a CISO, I want to see aggregate incident trends, so that I can assess whether agentic AI deployment is safe to expand. Acceptance: dashboard shows incident volume by type/severity over time, filterable.

US-04 — As a CISO or clinical informatics lead, I want to see rflx's own accuracy against its stated safety baseline, so that I can trust the guardrail is performing as claimed without asking an engineer to run or interpret the eval suite myself. Acceptance: `/eval` shows the current Go/No-Go verdict and all three underlying metrics (catch rate, false-positive rate, latency) with their targets, sourced from the same eval harness run cited elsewhere in this document — no repo access or CLI required.

7.2 Functional Requirements

ID	Requirement	Priority
FR1	System accepts structured action requests via API (agent_id, action_type, payload, context)	P0
FR2	System runs injection pre-screen before clinical risk classification	P0
FR3	System classifies every action into LOW / MEDIUM / HIGH / CRITICAL risk tiers	P0
FR4	System applies policy rules mapping (action_type, risk_tier) → decision	P0
FR5	System persists every decision with full audit context, including token cost	P0
FR6	Escalated actions surface in the Next.js reviewer queue with approve/reject controls	P0
FR7	Dashboard aggregates incidents by type, severity, and time	P1

7.3 Non-Functional Requirements

- **Performance:** P95 guardrail decision latency ~13s (P50 ~4.5s) — measured, accepted floor per §1's Success Metrics note, not a request-handling budget
 - **Reliability:** every action request produces exactly one logged decision
 - **Security:** no real PHI in any environment; synthetic data only
 - **Auditability:** every decision is immutable once logged (append-only audit table)
 - **Compliance framing:** designed to align with HIPAA §164.312 technical safeguard categories — not a HIPAA-compliant system, never describe it as one
-

Assumptions Made

- Assumed 2–2.5 weeks at ~20–25 hrs/week as the primary build target
- Assumed no live EHR sandbox access is available, hence the simulated-agent architecture
- Assumed OpenAI API access means a real platform.openai.com account with billing enabled, not only a ChatGPT Plus subscription — flagged for the reader to confirm
- Assumed Azure AI Content Safety and Netlify free tiers remain available at roughly their current limits through the build window
- Assumed existing Next.js/Netlify familiarity extends cleanly to using Next.js for backend API routes as well as the frontend
- Azure Foundry subscription confirmed in hand — no longer an assumption; still separate from the Azure AI Content Safety resource
- Pricing figures referenced throughout are sourced from third-party aggregators as of early August 2026 — verify before quoting confidently

Open Questions

1. Which EHR sandbox (if any) would be targeted for the MVP1 phase's real integration? — still open.
2. ~~Should the fairness/bias stratified eval approach be built into the MVP eval run, or deferred to the first post-demo iteration?~~ **Resolved:** built into the MVP eval run, not deferred. Design: docs/engineering/architecture.md 's Evaluation Framework section (stratifies benign eval cases by Synthea-coded age band, sex, and race). Implementation contract: specs/08-eval-harness.md . (The original docs/design.md §14.5 cross-reference no longer resolves — that file is now the visual design system doc, superseded by the structure in CLAUDE.md ; the fairness design lives in the two files linked above instead.)
3. ~~Is Microsoft Foundry instrumentation worth prioritizing to P0, or does it stay P1 and get cut first if the schedule compresses?~~ **Resolved:** stays P1, first to cut if the schedule compresses. docs/engineering/build-stages.md and specs/07-observability.md .

For build purposes: this file covers product strategy and requirements (what to build and why). See docs/engineering/architecture.md and specs/ for architecture, API contracts, database schema, and model/prompt strategy; docs/design.md for the visual design system; and skills/ for domain-specific implementation guidance.